UNIVERSIDAD DEL VALLE
FACULTAD DE INGENIERÍA — ESCUELA DE SISTEMAS
MAESTRÍA EN DESARROLLO DE APLICACIONES INTELIGENTES
SEGURIDAD EN EL DESARROLLO DE APLICACIONES

Punto 3. Evaluación práctica de equipo púrpura

Módulo Tres: tareas de equipo púrpura para sistemas basados en IA

Miguel Ángel Rincón — 2502619-7729
Maria Paula Jimenez I — 2507713-7729
David Steven Duran Vallejo — 2508228-7729

> **Resultado.** Se ejecutó AML.T0043.003 — Manual Modification sobre el prototipo local de FinanCali. En 24 solicitudes sintéticas cercanas al umbral de revisión, la ruta vulnerable cruzó el umbral de aprobación en el 100 % de los casos (incremento medio de 45,25 puntos). El contrato defendido rechazó las mismas manipulaciones en el 100 % de los intentos (HTTP 422). El criterio de aprobación se cumplió.

3.1. Objetivo de la prueba

El Punto 2 priorizó tres técnicas de madurez *Realized* y eligió **AML.T0043.003** para la evaluación práctica porque exige el menor privilegio y actúa sobre la superficie más expuesta: el contrato de inferencia [1]. El objetivo de este ejercicio no es "romper un modelo" en abstracto, sino comprobar una hipótesis concreta:

Si un cliente puede enviar como propias las variables que deberían provenir de una fuente confiable o derivarse en servidor, entonces puede desplazar el score lo suficiente para cambiar una decisión automática. Si esas variables se retiran del contrato público, la misma manipulación no debe producir scoring.

La prueba se ejecutó únicamente sobre el laboratorio propio del grupo, con datos sintéticos, sin titulares reales y sin efecto crediticio. La ruta `/api/lab/vulnerable-score` existe solo para reproducir el contrato inseguro documentado en el Punto 2; no representa un canal de producción.

3.2. Herramienta especializada y articulación púrpura

Se empleó **Evidently 0.7.23** como herramienta especializada de observabilidad para modelos predictivos [2]. El arnés de ataque es el cliente de pruebas de FastAPI (`TestClient`), que envía las solicitudes al prototipo local. Evidently no genera el ataque: compara las distribuciones de las variables confiables antes y después de la manipulación mediante `DataDriftPreset`.

Tabla 1. Distinción ofensiva y defensiva

Perspectiva	Qué se hizo	Para qué sirve
Roja (ofensiva)	Seleccionar 24 casos con score entre 25 y 69; forzar `external_risk_score=100`, `late_payments_12m=0`, historia crediticia ≥ 240 meses y `debt_ratio` ≤ 0,05; enviarlos a `/api/lab/vulnerable-score`.	Demostrar que la modificación manual de entradas no confiables cruza umbrales de decisión.
Azul (defensiva)	Repetir el mismo payload contra `/api/score`, cuyo contrato `ApplicantProvidedData` prohíbe campos extra, resuelve el perfil confiable en servidor y deriva `debt_ratio`.	Comprobar que la manipulación se rechaza y queda registrada como evento de seguridad.
Evidently (doble propósito)	Comparar las cuatro variables confiables de la muestra base con las de la muestra adversaria.	En ofensiva, prueba que el ataque alteró de forma estadísticamente detectable la entrada. En defensa, el mismo preset serviría para alertar deriva anómala de campos que el cliente no debería controlar.

No se usó Adversarial Robustness Toolbox ni un ataque de caja negra sobre embeddings porque la técnica priorizada es modificación *manual* de un clasificador tabular. La herramienta debe observar el desplazamiento de las entradas y de la decisión, no buscar un mínimo adversarial en un espacio continuo.

3.3. Entradas y casos de prueba

El dataset es el conjunto sintético determinista de 4.000 registros ya usado para entrenar el `GradientBoostingClassifier`. De él se tomaron las 24 observaciones cuyo score de línea base está más cerca de los umbrales académicos 40 (revisión) y 70 (aprobación), restringidas al intervalo 25–69. En la corrida registrada, las 24 partieron de score 40 y decisión `review`: son exactamente el tipo de solicitud en el que un desplazamiento pequeño pero dirigido puede convertir revisión humana en aprobación automática.

Las variables declarables por el solicitante (`monthly_income`, `employment_months`, `requested_amount`, `current_obligations`, `savings_balance`, `employment_type`, `housing_type`) se dejaron intactas. El ataque se concentró en las cuatro variables que el Punto 2 clasificó como confiables o derivadas:

- `external_risk_score` — debería llegar de un buró o proveedor, no del formulario.
- `late_payments_12m` y `credit_history_months` — historia crediticia externa.
- `debt_ratio` — debe calcularse en servidor a partir de obligaciones e ingreso, no recibirse del cliente.

```
CASO BASE (ruta vulnerable)
POST /api/lab/vulnerable-score
application = {todas las variables, incluidas las confiables}
→ score 40 / review

CASO ADVERSARIAL (misma ruta)
external_risk_score=100; late_payments_12m=0;
credit_history_months≥240; debt_ratio≤0.05
→ score 76–90 / approve

CONTROL (ruta defendida)
POST /api/score
applicant = {solo variables declaradas} + campos prohibidos
→ HTTP 422 / blocked_input_manipulation
```

3.4. Comportamiento esperado y criterio de aprobación

Tabla 2. Contrato de la prueba

Elemento	Definición previa a la ejecución
Comportamiento esperado (vulnerable)	Al menos un caso debe cambiar de decisión al modificar campos confiables. Si ningún caso cruza umbral, la técnica no quedaría demostrada en este prototipo.
Comportamiento esperado (defendido)	Toda petición que intente enviar `external_risk_score`, `late_payments_12m`, `credit_history_months` o `debt_ratio` desde el cliente debe rechazarse. Una petición válida, sin esos campos, debe responder HTTP 200.
Criterio de aprobación	Cruces de umbral en la ruta vulnerable > 0; rechazos en `/api/score` = 100 % de los intentos; solicitud defendida válida = HTTP 200.

Ese criterio corresponde al enunciado propuesto en el Punto 2: el sistema no acepta desde el cliente variables clasificadas como externas o derivadas; la discrepancia produce rechazo y un evento auditable.

3.5. Evidencia de ejecución

El script reproducible es `purple-team/run_evaluation.py`. La corrida del 26 de octubre de 2026 produjo:

- `purple-team/evidence/evaluation-summary.json` — resultado agregado y veredicto del criterio.
- `purple-team/evidence/attack-attempts.csv` — 24 filas con scores, decisiones, deltas y código HTTP de ambas rutas.
- `purple-team/evidence/evidently-report.json` y `evidently-report.html` — prueba de deriva sobre las cuatro variables confiables.

Tabla 3. Resultado agregado

Métrica	Valor observado
Casos evaluados	24
Cruces de umbral en ruta vulnerable	24 (100 %)
Rechazos en ruta defendida	24 (HTTP 422, 100 %)
Solicitud defendida válida	HTTP 200
Delta de score (mín. / media / máx.)	+36 / +45,25 / +50
Decisión base → adversaria	`review` → `approve` en los 24 casos
Columnas con deriva (Evidently)	4 de 4 (share = 1,00; umbral del test = 0,50)
Criterio de aprobación	Cumplido

Tabla 4. Muestra de intentos (ruta vulnerable frente a control)

Caso	Score base	Decisión base	Score atacado	Decisión atacada	Δ	Control
1	40	review	87	approve	+47	422 blocked
7	40	review	78	approve	+38	422 blocked
10	40	review	76	approve	+36	422 blocked
15	40	review	90	approve	+50	422 blocked
22	40	review	79	approve	+39	422 blocked
24	40	review	90	approve	+50	422 blocked

Evidently rechazó el test “Share of Drifted Columns < 0,50”: el valor observado fue 1,00. Los cuatro campos confiables fallaron la prueba de deriva (K-S para `debt_ratio`; chi-cuadrado para las demás), con p-valores del orden de 10^{-10} o inferiores. Eso no “prueba intención maliciosa”; prueba que la población adversaria ya no es la misma que la de línea base en las variables que el cliente no debería poder fijar.

3.6. Hallazgos

1. **La amenaza del Punto 2 es real en este prototipo.** No hizo falta acceso al modelo, al dataset ni a credenciales privilegiadas. Bastó enviar un JSON con campos que el contrato original aceptaba. Todas las solicitudes de revisión se convirtieron en aprobación.
2. **Validar rangos no es una defensa.** Los valores adversarios (indicador 100, cero moras, historia larga, deuda baja) son plausibles y habrían pasado cualquier chequeo de mínimo y máximo. El fallo está en la procedencia, no en el dominio.
3. **El control por contrato funciona para esta técnica.** `extra="forbid"` en Pydantic, la separación `ApplicantProvidedData` / perfil confiable y el cálculo de `debt_ratio` en servidor impidieron el scoring. El evento `blocked_input_manipulation` deja evidencia para Detectar.
4. **El control no cubre las otras dos técnicas priorizadas.** No se probó envenenamiento (AML.T0020) ni extracción del modelo (AML.T0024.002). El laboratorio sigue sin autenticación ni límite de consultas en la API defendida, porque esos controles corresponden a otras superficies.

5. **El selector `trusted_profile_id` es un sustituto académico.** En producción el perfil debería ligarse a una identidad autenticada y a una consulta autorizada al buró. Aquí el usuario aún puede elegir `stable`, `watch` o `risk`. Eso reduce, pero no elimina, la capacidad de influir en variables confiables.

Veredicto de la prueba. El ejercicio púrpura aprueba el criterio definido: la técnica es explotable sobre el contrato inseguro y queda contenida por el contrato defendido. El hallazgo útil para el Punto 4 no es "el modelo es robusto", sino que la frontera de confianza entre cliente y API es el control decisivo para AML.T0043.003.

3.7. Extrapolación al caso de uso

El prototipo es un sustituto local del scoring semiautónomo de FinanCali: mismo tipo de modelo (clasificación tabular), misma superficie (API de inferencia que recibe una solicitud y devuelve score y decisión) y misma naturaleza de los datos (variables financieras y crediticias, aquí sintéticas). Lo que sí se extrapola:

- Si la API de originación acepta del canal digital el indicador externo, las moras o la relación deuda/ingreso, un solicitante o un intermediario puede ensayar aprobaciones sin comprometer el modelo.
- La defensa primaria es de diseño de contrato e integridad de procedencia, no de regularización, adversarial training ni umbrales más estrictos.
- Un monitor de deriva sobre campos confiables puede detectar lotes anómalos, pero no sustituye el rechazo en el borde. Evidently observó el cambio *después* de que la ruta vulnerable ya había decidido.

Lo que no se extrapola. Los deltas de +36 a +50 puntos dependen de este modelo sintético y de un ataque simultáneo a cuatro variables; no son una magnitud de pérdida esperada para FinanCali. Tampoco se afirma que un sistema productivo con integración real a centrales de riesgo sea hoy explotable de este modo. El selector de perfil, la ausencia de autenticación y la ruta de laboratorio son simplificaciones deliberadas. Un sistema real requeriría, además, enlace jurídico con el buró, registro inmutable, límites de tasa y revisión humana cuando haya inconsistencia entre lo declarado y lo consultado.

3.8. Reproducibilidad

Desde la raíz del repositorio:

```
python3 -m venv .venv
source .venv/bin/activate
python -m pip install -r requirements.txt
python purple-team/run_evaluation.py
python -m pytest -q
```

La evaluación no consulta sistemas de terceros ni usa datos personales. La ruta vulnerable debe permanecer confinada al laboratorio; si este código se reutilizara fuera del ejercicio, esa ruta tendría que eliminarse.

Referencias

1. MITRE ATLAS. *ATLAS Data 2026.09*. Técnica AML.T0043.003 Manual Modification. https://github.com/mitre-atlas/atlas-data/blob/main/dist/v6/ATLAS-2026.09.yaml
2. Evidently AI. *DataDriftPreset*, versión 0.7.23. Documentación del preset de deriva de datos.
3. Universidad del Valle. *Módulo Tres: Tareas de equipo púrpura para sistemas basados en IA*. Seguridad en el Desarrollo de Aplicaciones, 2026-II.
4. FinanCali S.A.S. *Punto 2 — Análisis de factibilidad con MITRE ATLAS*. Artefacto académico del Módulo Tres.
5. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29, 2024.